

NOTE CONCEPTUELLE

Solution Anti-Spyware : Automatisation de la Détection d'une Écoute Active

Proposition Technique

Ce document présente une architecture logicielle permettant de détecter automatiquement une écoute active sur un appareil mobile (Android). La solution repose sur trois piliers complémentaires : la surveillance des flux réseau, la détection de l'activation furtive des capteurs, et la vérification de l'intégrité du noyau système (kernel).

1. Surveillance des Flux Réseau

Un spyware doit impérativement communiquer avec un serveur distant de type C2 (Command & Control) pour exfiltrer les données collectées. Cette communication constitue sa principale surface de détection. Trois familles de comportements réseau anormaux sont ciblées.

1.1 Connexions sortantes furtives

L'agent surveille en continu toutes les connexions sortantes et leur attribue un score de risque selon plusieurs critères cumulatifs : activité réseau lorsque l'écran est éteint depuis plusieurs minutes, connexion initiée par un processus absent de la liste blanche des applications autorisées, plage horaire suspecte (entre 2h et 6h du matin), destination vers une adresse IP ou un port inhabituel. Si le score total dépasse 70, la connexion est bloquée.

⚠ **Alerte générée** : Connexion furtive détectée à 3h12 Processus inconnu vers IP non référencée.

1.2 Pics d'upload anormaux

L'agent mesure en continu le volume de données sortantes par application. Il déclenche une alerte lors d'un envoi massif soudain (> 50 Mo en quelques minutes), d'envois répétés en arrière-plan ou en pleine nuit, ou d'un upload provenant d'une application habituellement silencieuse.

⚠ **Alerte générée** : 120 Mo envoyés à 3h14 vers une IP inconnue Processus non identifié.

1.3 Requêtes DNS vers des domaines DGA

Les domaines générés algorithmiquement (DGA) sont une signature caractéristique des infrastructures C2 modernes. L'agent intercepte chaque requête DNS et calcule un score basé sur l'entropie du nom de domaine, sa longueur, la rareté des voyelles, et la présence d'extensions suspectes (.ru, .xyz, .cc). Un score supérieur à 70 entraîne le blocage immédiat de la requête.

⚠ **Alerte générée** : Domaine suspect bloqué : xylphqrzbwxf.xyz Score DGA : 84/100.

2. Détection de l'Activation Furtive des Capteurs

Sur Android, les applications accèdent au microphone et à la caméra via les API système AudioRecord/MediaRecorder et Camera2/CameraX. Un malware peut appeler ces API en arrière-plan sans déclencher le voyant LED, rendant l'activation invisible pour l'utilisateur. Trois mécanismes de détection sont combinés.

2.1 Audit des API en temps réel

L'agent s'enregistre comme observateur bas niveau via les hooks système. Pour chaque appel aux API audio ou vidéo, il identifie le PID du processus appelant et vérifie s'il correspond à une application légitime au premier plan. Tout appel émanant d'un daemon inconnu ou d'une application en arrière-plan est immédiatement marqué comme suspect.

2.2 Analyse de /proc/asound/

Le système de fichiers virtuel /proc/asound/ expose en temps réel l'état du matériel audio. L'agent lit périodiquement (toutes les 2 à 3 secondes) le fichier /proc/asound/card0/pcm0c/sub0/status. Si le champ state passe à RUNNING sans qu'aucune application audio ne soit active au premier plan, l'activation est considérée comme non justifiée. Cette lecture directe du registre kernel est impossible à masquer par un malware applicatif classique.

2.3 Corrélation comportementale

L'agent croise simultanément trois sources d'information : l'état du capteur (actif ou inactif), la liste des applications au premier plan via l'ActivityManager, et l'état de l'écran (allumé ou éteint). Une activation capteur sans application visible associée constitue un indicateur fort de compromission.

⚠ Alerte générée : *Microphone activé à 1h47 Aucune application audio au premier plan Écran éteint.*

3. Vérification de l'Intégrité du Kernel

Le kernel constitue la cible la plus critique : un attaquant qui compromet ce niveau peut masquer toute activité au système. La solution s'appuie sur deux mécanismes complémentaires pour détecter toute altération.

3.1 Mécanismes natifs de démarrage sécurisé

La solution exploite Secure Boot et dm-verity, deux mécanismes intégrés à Android, pour garantir l'intégrité du kernel et des partitions système dès le démarrage. Secure Boot vérifie la chaîne de signatures cryptographiques depuis le bootloader jusqu'au noyau. dm-verity assure que les blocs du système de fichiers n'ont pas été modifiés après installation.

3.2 Attestation d'intégrité distante

En complément, une attestation est réalisée via la Play Integrity API (Google), qui permet de vérifier à distance que le bootloader est verrouillé et que l'image système est intacte. Toute anomalie échec de vérification ou attestation invalide est interprétée comme un indicateur de compromission potentielle du kernel.

⚠ Alerte générée : *Intégrité système compromise : environnement non fiable détecté Altération du kernel ou du bootloader.*

Conclusion

Les trois modules décrits forment un système de détection en couches : la surveillance réseau identifie l'exfiltration, la surveillance des capteurs détecte la collecte, et la vérification kernel garantit la fiabilité de l'environnement d'exécution. Leur complémentarité permet de couvrir l'ensemble du cycle de vie d'une écoute active, de l'activation furtive des capteurs jusqu'à la transmission des données vers un serveur C2, sans dépendre d'une seule surface d'observation.